

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Postman Collection Structure and API Test Workflow Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Postman collection structure
Result Type	Testing workflow
Evidence Report File	04-postman-collection-structure-evidence-report.pdf
Testing Phase	API Test Organization
Tool / Component	Postman Collection
OWASP / Security Mapping	Testing Methodology Evidence
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

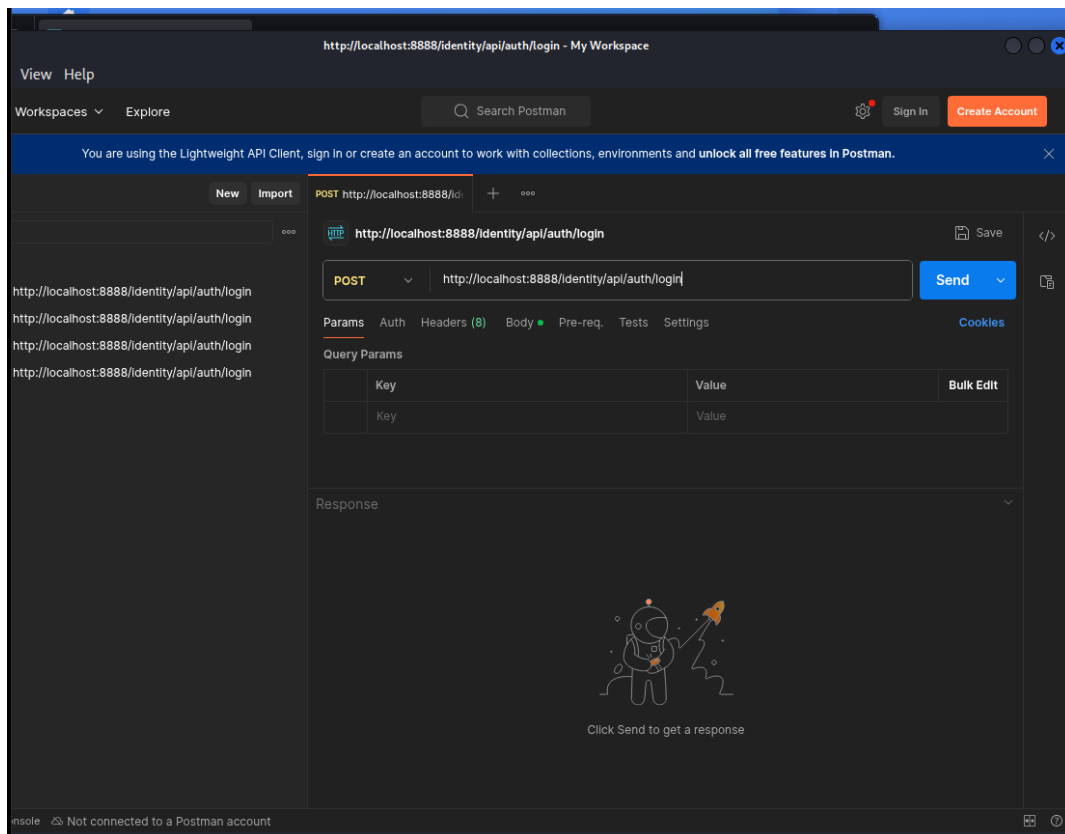


Figure 1 - Embedded screenshot evidence for: Postman collection structure

What this evidence proves

The screenshot shows a Postman collection/workspace structure used to organize API endpoints and tests. This supports methodology, repeatability, and evidence traceability.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	API Test Organization
Tool / Component	Postman Collection
Assessment Objective	Show that API requests were organized into a structured workflow for repeatable testing rather than executed randomly.
Result Type	Testing workflow
OWASP / Security Mapping	Testing Methodology Evidence

Why this evidence matters

A structured collection is important because API assessments require consistent token handling, endpoint grouping, repeatable requests, and clear evidence mapping.

Command / workflow used

```
Create Postman collection
Group requests by authentication, users, vehicles, reports, GraphQL, OAuth, and security tests
Use variables such as {{base_url}} and {{token}}
```

Sanitized output style

```
Collection: API Security Lab
Variables: {{base_url}}, {{token}}, {{user_id}}
Requests grouped by testing objective
```

3. Professional Interpretation

This evidence row should be interpreted as: **Testing workflow**.

This is not a vulnerability. Poor test organization can lead to missed endpoints, inconsistent evidence, or accidental exposure of secrets through Postman environments.

Assessor notes

Good for recruiters because it shows professional assessment discipline.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

This is not a vulnerability. Poor test organization can lead to missed endpoints, inconsistent evidence, or accidental exposure of secrets through Postman environments.

Recommended remediation / hardening actions

- Use variables instead of hardcoded secrets.
- Do not commit Postman environment files with tokens.
- Remove Authorization headers before publishing collections.
- Document each request purpose and expected result.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Postman environment values.
- Bearer tokens.
- Cookies.
- Email addresses and test credentials.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[Postman collection structure](./reports/evidence/04-postman-collection-structure-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.